LOT-HW-03 — LOT API Device Connector (v1, implemented S3)

Code: `src/server/routes/device-api.ts` · Model: `src/server/models/device.ts` · Migration: `migrations/20261111120000_create-devices.cjs` · Test: `hardware/tools/device-api-e2e.mjs` (23/23 pass on Postgres 16)

AUTH

- **User routes** use the normal site cookie session.
- **Device routes** use `Authorization: Bearer lotd_<48 hex>`. The token is returned **once** at pairing; the server stores only its SHA-256. Revoke = instant 401.
- Optional header `X-LOT-FW: 0.1.0` records the firmware version.

USER ROUTES (SITE, SIGNED IN)

Method	Path	Body	Returns
GET	`/api/devices`	—	`{devices:[{id,name,firmware,lastSeenAt,createdAt}]}`
POST	`/api/devices`	`{name?}`	`{id,name,token}` (max 5 devices per user)
DELETE	`/api/devices/:id`	—	200 / 404
POST	`/api/devices/notice`	`{text}`	`{id,text}`; queues a notice (≤ 80 chars)

DEVICE ROUTES

Method	Path	Body	Returns
GET	`/api/device/inbox`	—	`{notices:[{id,text,ts}], poll_s:60}`, pending only, last 24 h, newest 5
POST	`/api/device/ack`	`{ids:[...]}` (≤ 20)	`{acked:n}`
POST	`/api/device/event`	`{type:"copy", notice_id}` or `{type:"copy", text}`	`{id}`; writes Log `device_copy`
POST	`/api/device/event`	`{type:"sensor", t_c, rh, hpa, iaq, lux, battery}`	`{stored}`; at most 1 per 5 min; values clamped

STORAGE

- `devices` table (new): `id, userId, name, tokenHash, firmware, lastSeenAt, revokedAt, metadata`.
- Notices, copies and sensor readings reuse the `logs` table:
  - `device_notice` is hidden. Its `metadata.status` is `pending` until acked, then `delivered`.
  - `device_copy` is **shown in the Log tab** as `PAGER: <text>` plus the device name.
  - `device_sensor` is hidden. Readings are in `metadata`, ready to feed the weather and environment signals.

SENDING AN AUTONOMOUS NOTICE FROM THE AI SIDE

```
import { queueDeviceNotice } from '#server/routes/device-api'
await queueDeviceNotice(user.id, 'Coffee time!', 'ai')   // trims to one line, 80 chars
```

Not yet wired into a scheduled job. Next step: pick 1–3 nudges a day from the existing self-care / circadian signals and respect quiet hours (S4).

SECURITY CHECKS COVERED BY THE TEST

No token → 401 · bad token → 401 · revoked → 401 · another user cannot revoke your device · a device cannot copy another user's notice · the raw token is never stored · notice length clamp · sensor clamp and rate limit.

DEPLOY NOTES

1. `npm run migrations:up` creates `devices`. The migration only adds a table, and its `down` drops it.
2. No env vars needed. TLS terminates at Caddy as for the rest of the site.
3. Before EVT: add per-IP rate limiting on `/api/device/*` (S4).